



# From Reactive to Proactive

AI-Powered Threat Modeling &  
Code Review in the SSDLC

Sharon Ohayon Pshoul



# Whoami?

## Sharon -

Product Security Architect and a Team Leader @ Axonius

OWASP Israel board member

Ex-pen tester, forever curious

Always up for a good tech talk or ice cream 🍦

Married to Dima and a dog mom to Belle



@sharon-ohayon

## Contributors

**Avri Schneider**



**Michael Goberman**



**Alexey Shchukarev**



# Agenda

01 Introduction

---

02 Multi Agent AI

---

03 Code Review With Crews-Control

---

04 Threat Model With Crews-Control

---

05 Lessons learned

---

06 Q&A

# Introduction

# Introduction

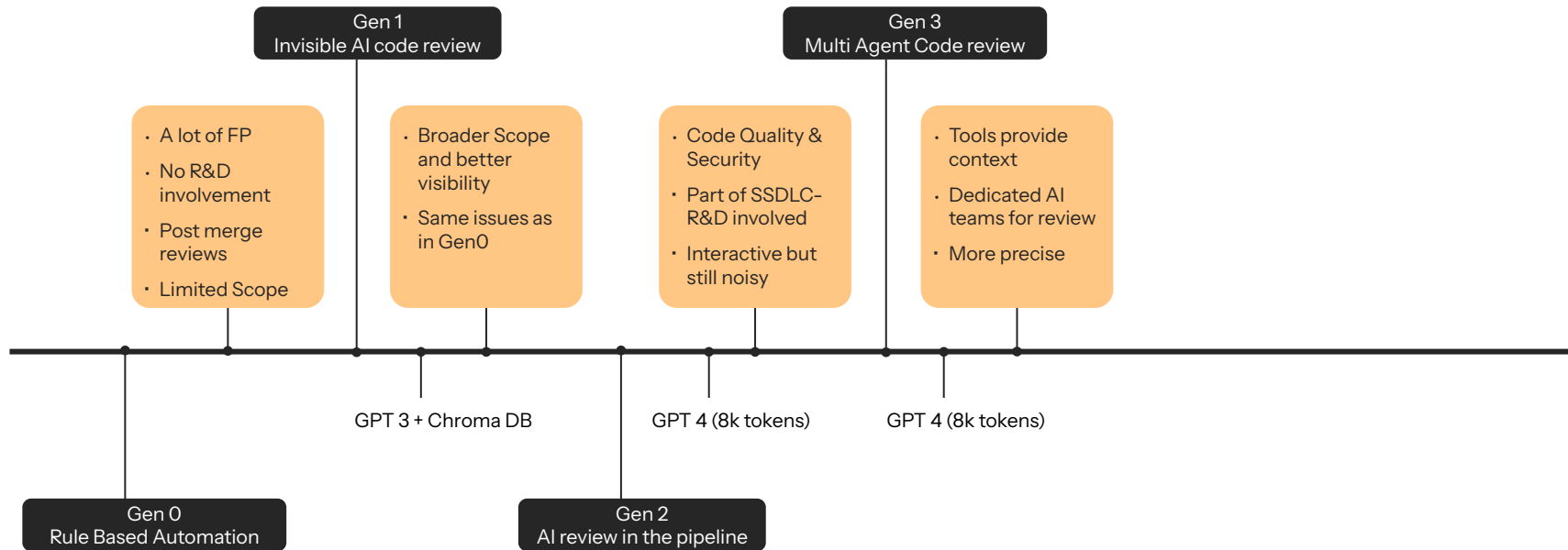
*What is the challenge?*

## Shift Left

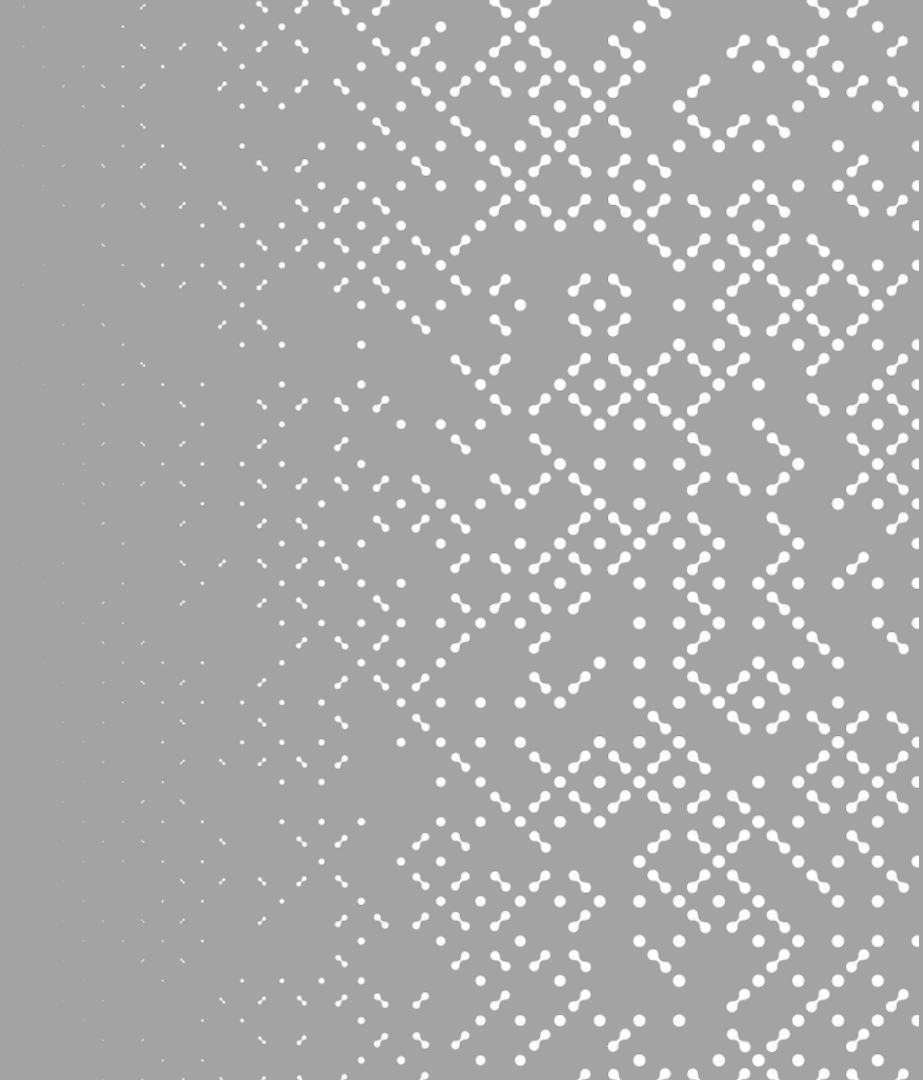
- The target
  - Review every design as early as possible
  - Review every implementation
- The challenge
  - Even 1:50 security experts:Developer is not enough
- The solution
  - Automate as much as possible
  - Identify risks as early as possible

# Introduction

## *The Journey*



# Multi Agent AI



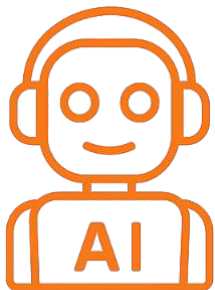
# CrewAI

## *What is this platform?*

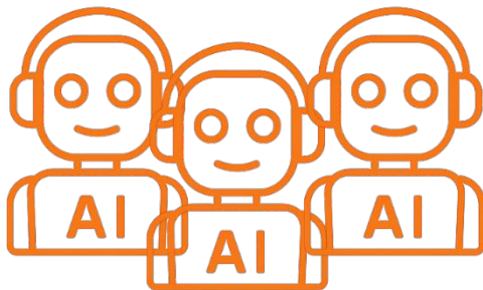
### Multi Agent Platform Components

CrewAI is an open-source and Python-based framework for building AI agents that collaborate as a team to complete complex tasks using defined tools and roles.

#### Agent



#### Crew



#### Tool



#### Task

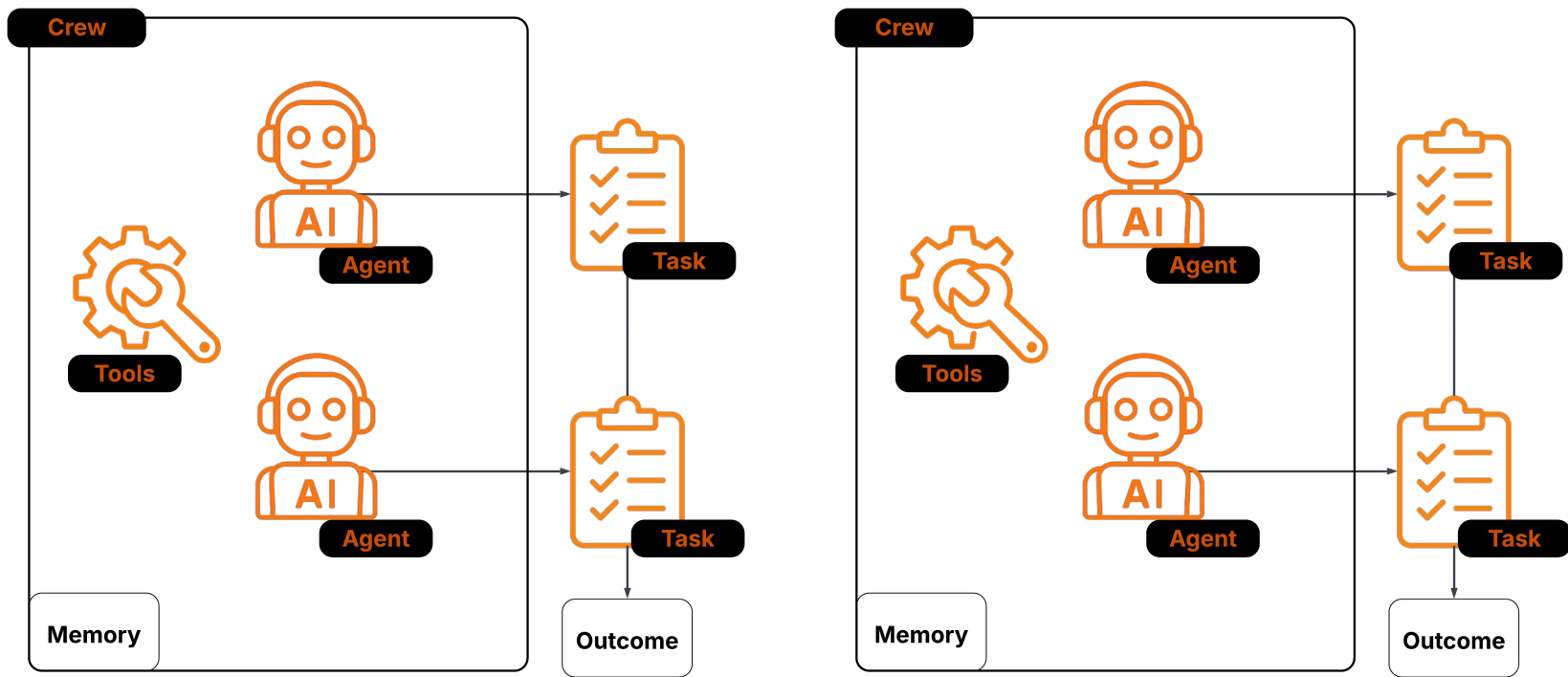




# CrewAI

## *What is the workflow?*

Multi Agent Platform Process - Crew of AI agents collaborates to complete complex tasks.



```

settings:
  output_results: true

user_inputs:
  input_data:
    title: "Input Data"
    description: "Data to be processed."

crews:
  # Define a "Crew" for a specific goal
  DataProcessorCrew:
    output_name: processed_data
    output_naming_template: 'processed_data.md'
    agents:
      # Agents are the workers within a Crew
      processor_agent:
        role: "Data Transformation Expert"
        goal: "Transform raw input data into a structured format."
        tools:
          # Tools agents can use to achieve their goals
          - data_parser_tool
          - validator_tool
        backstory: "Experienced in cleaning and structuring diverse datasets."
      tasks:
        # Tasks define specific actions for an agent
        process_input_task:
          agent: processor_agent
          description: "Parse and validate the {{input_data}}."
          expected_output: "A clean, JSON-formatted output of the input data."

  # Another Crew can depend on the output of the first
  summaryProcessorCrew:
    # Here we reuse the output of the first crew
    input_data: "{{ processed_data }}"
    output_naming_template: 'summary_report.md'
    agents:
      summary_agent:
        role: "Report Generator"
        goal: "Create a concise summary from processed data."
      tasks:
        summarize_task:
          agent: summary_agent
          description: "Summarize the output from DataProcessorCrew."

```

A crew

An Agent

Tools

A

Task



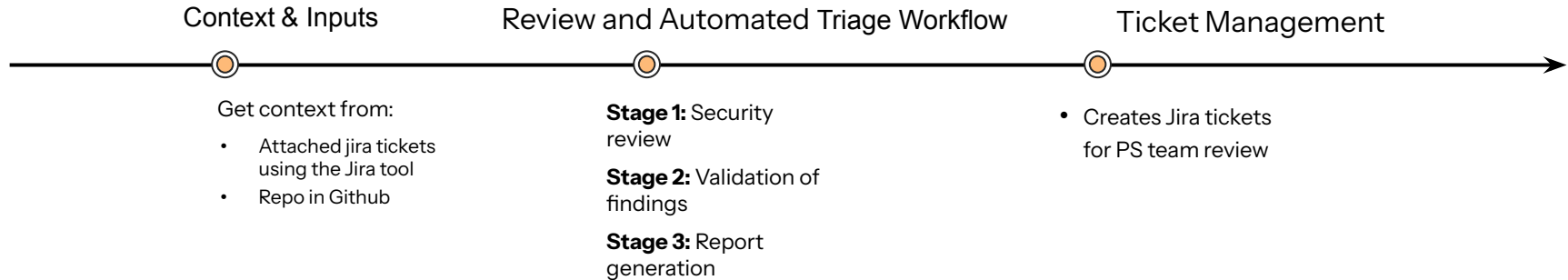
1. converts the config into Python objects compatible with crewAI
2. dynamically builds crewAI agents, tasks, tools, and orchestrates them
3. handles execution order, data passing, and artifact generation

crewai

# Code Review With AI Agents

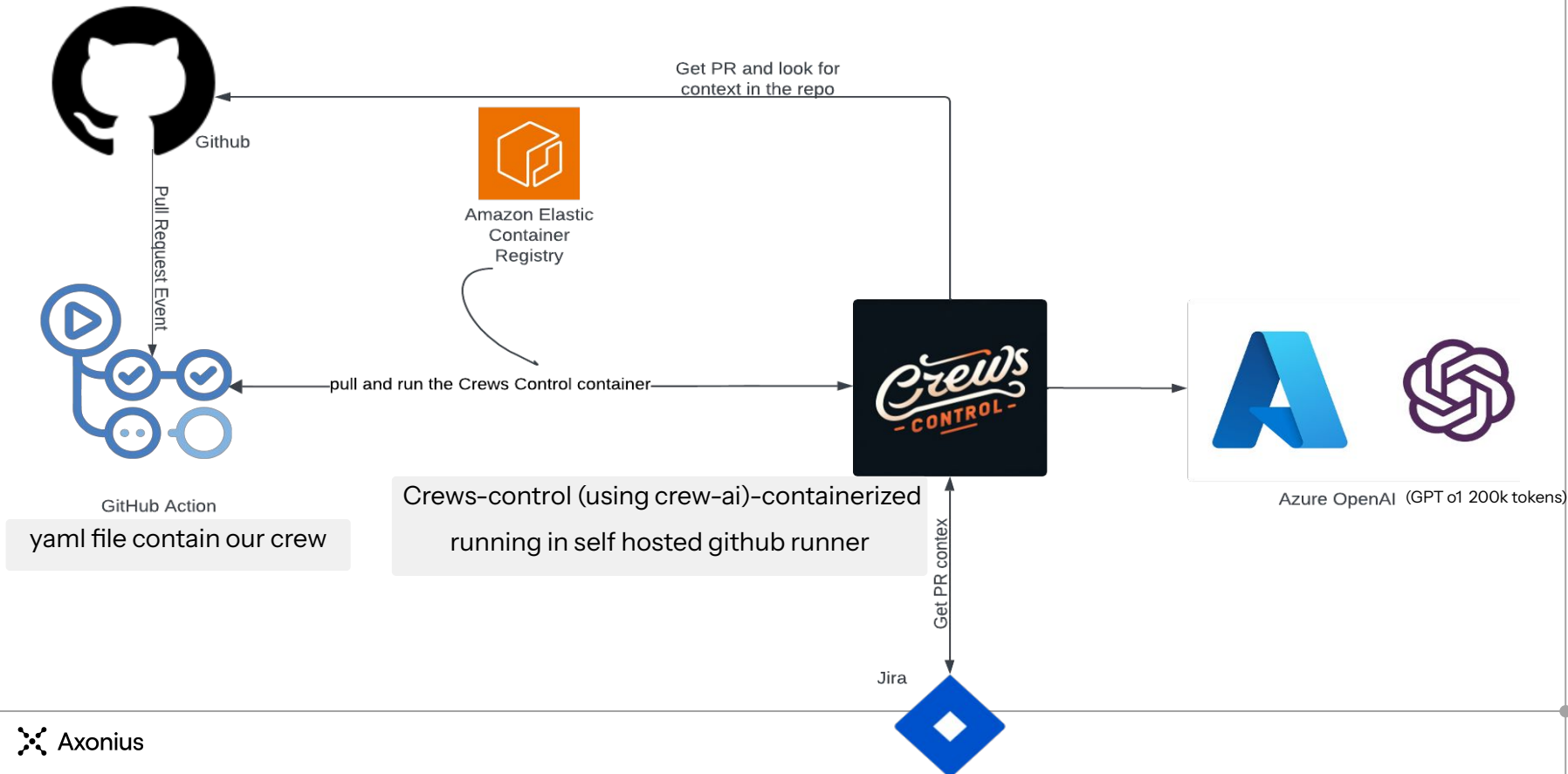
# Crews Control Powered Code Review

## *Features and flow*



# Crews Control Powered Code Review

## *Design & Deployment*



# Crews Control Powered Code Review

## *Example Finding*

```
content="The code diff shows changes made to the [REDACTED] adapter's '[REDACTED].py' file. The following functions and modules were reviewed: [REDACTED],  
[REDACTED].\n\nThe changes involve adding new fields to the '[REDACTED]' class.  
These fields include sensitive information such as 'SSN', 'Address Zip Code', and 'National ID'. Since the '[REDACTED]' class is responsible for representing  
user information, the addition of these fields could pose a security risk if adequate measures are not taken to secure the data. \n\nIt is recommended to review the  
implementation of the '[REDACTED]' class and ensure that proper access controls and data encryption are in place to protect sensitive user information."  
-----  
source files:['adapters/[REDACTED].py']
```

result:

**Private Information – Not for Distribution]**

# Crews Control Powered Code Review

## *Main Features*



### Development Experience

- No-code, declarative setup  
CLI-friendly and scriptable
- Fully containerized for easy deployment
- GitHub Action integration



### Smarter Code Review

- More accurate results, less noise
- Domain-specific AI personas
- Built-in tools for insight and context



### Scalability & Extensibility

- Benchmark mode: bulk task execution & validation
- 100% open source –  
crews-control



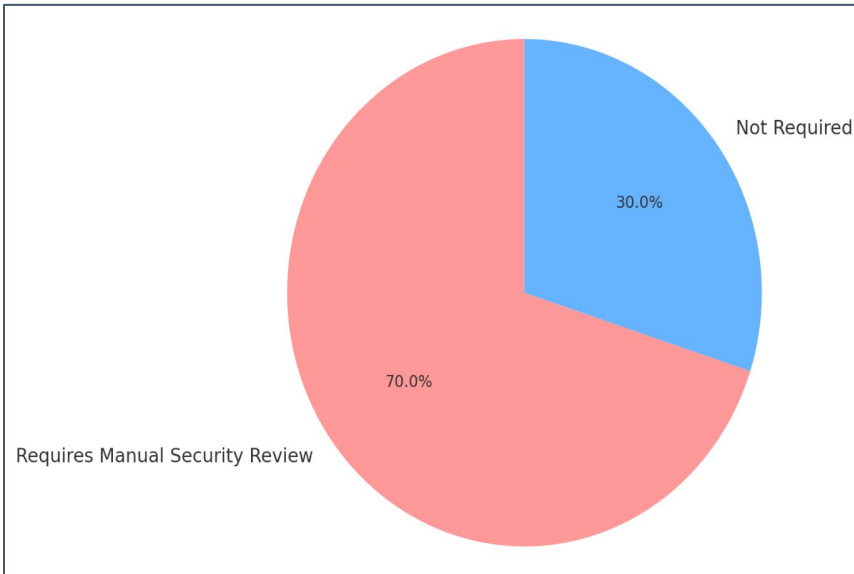
# Crews Control Powered Code Review

*Reduce FP - compare to older Gens*

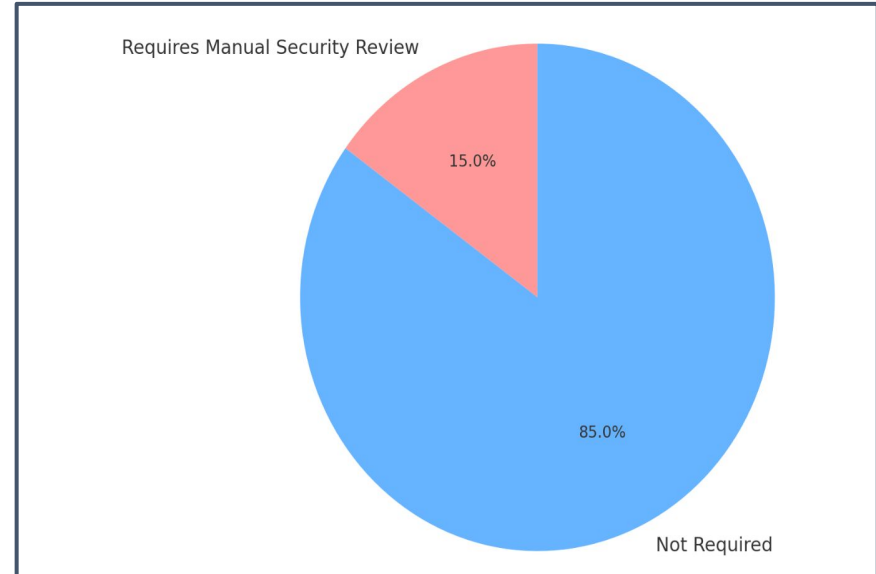


CodeRabbit\*

Before Crews-Control



With Crews-Control





# Crews Control Powered Code Review

*Reduce FP*

 **AlertPR**  
Software project

 Back to project

## DEFAULT FILTERS

All issues

My open issues

Reported by me

Open issues

Done issues

Projects / AlertPR

## Issues

Share ▾

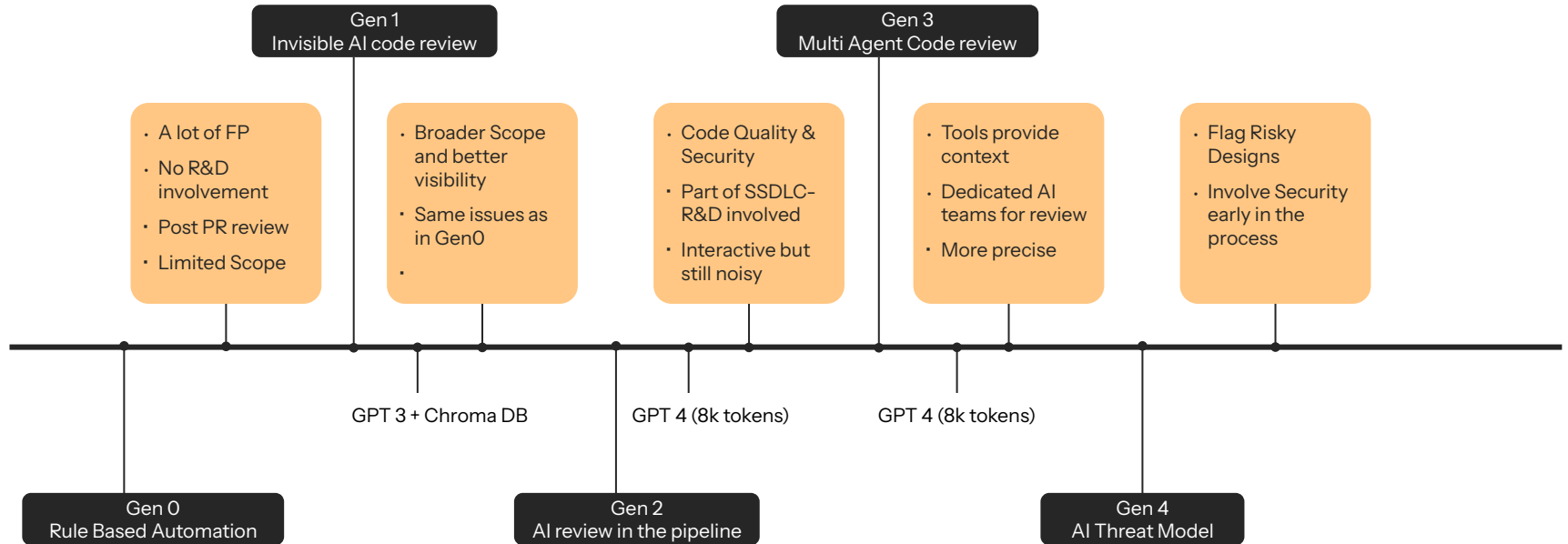
Export issues

project = "AL" ORDER BY created DESC

| Key     | Summary                                              | Status         | Assignee                                                                                       | Reporter                                                                                                |
|---------|------------------------------------------------------|----------------|------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| AL-6123 | PR 41641 - Axonius/[REDACTED] CREWS-CONTROL-TEST     | AI_DISCARDED ▾ |  Unassigned |  AlertPR ServiceUser |
| AL-6122 | [Repo: [REDACTED] PR: 41641] - found security issues | AI_REVIEW ▾    |  Unassigned |  AlertPR ServiceUser |
| AL-6121 | 41310 Axonius [REDACTED] CREWS-CONTROL-TEST          | AI_DISCARDED ▾ |  Unassigned |  AlertPR ServiceUser |
| AL-6120 | [Repo: [REDACTED] PR: 41310] - found security issues | AI_REVIEW ▾    |  Unassigned |  AlertPR ServiceUser |

# Crews Control Powered Threat Modeling

## *The Journey*



# Threat Model With AI Agents

# Crews Control Powered Threat Model

## *Main Features*

### **Context & Inputs**

- Pulls context from Jira (PRDs), Confluence and Lucid
- Reads architecture diagrams
- Identifies transitive Jira tickets

### **Threat Modeling Engine**

- Dedicated threat model inspired by STRIDE to avoid noise
- Highlights risks and attack scenarios
- Findings and recommendations are automatically added to Jira tickets for full visibility

### **Human Collaboration**

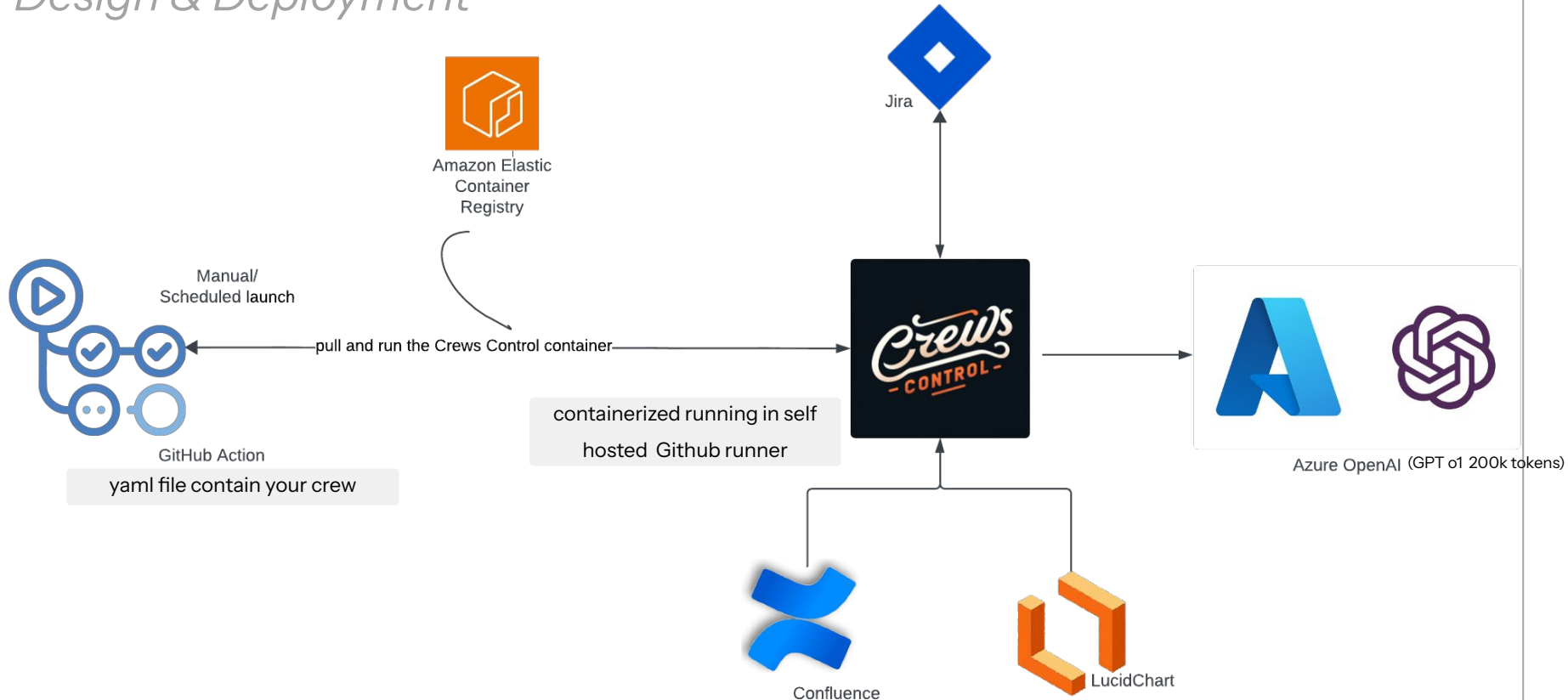
- Surfaces key insights for product managers
- Flags critical tickets for security architects
- Aims to provide context for code reviews

### **Automation & Architecture**

- Fully containerized + no-code (CrewsControl-based)
- Runs as a scheduled/manual GitHub Action
- Continuously monitors tickets, flags and re-review them for upon impactful changes

# Crews Control Powered Threat Modeling

## *Design & Deployment*



# Crews Control Powered Threat Model

*Example output*

 AL-17955 

## Security Threat Model Review for [REDACTED]: Key Findings

+ Add

 Apps

General

Timestamps

Pull Request Data

### Description

**Private Information – Not for Distribution]**

**Key Risks Identified (from Threat Model):**

**Private Information – Not for Distribution]**

**Key Mitigation Recommendations (from Threat Model):**

**Private Information – Not for Distribution]**

# Crews Control Powered Threat Model

*Example output*

**Potential Impact (Security):**

**Private Information – Not for Distribution]**

**Recommendations from Feature Analysis (for Original Ticket):**

**Private Information – Not for Distribution]**

Lessons learned



# Finetuning: Improving precision through prompt design & structure

## *Examples - Diagram understanding*

here's is an example of a diagram that was attached to a design we tried to threat model with and without the PlantUML textual representation conversion.

**Private Information – Not for Distribution]**

```
@startuml

skinparam linetype ortho

package "EC2 Instance Contents" {
    database ConfigDB as configdb <<secured>>
    database Assets as assets <<secured>>
}

node Redis as redis {
    [Store IP]
}

node "ECS garbage collector" as garbageCollector {
    [Timeline calculator]
}

node "Amazon Elastic Container Service" as ecs {
    node "ECS Fargate Container" as fargate {
        component task1 as task1 <<writable>>
        component task2 as task2 <<readonly>>
        component task3 as task3 <<readonly>>
        component task4 as task4 <<readonly>>
    }
}
```

# Finetuning: Improving precision through prompt design & structure

*Examples - Diagram Understanding*

**Private Information – Not for Distribution]**

# Finetuning: Improving precision through prompt design & structure

*Examples - Diagram Understanding*

**Private Information – Not for Distribution]**

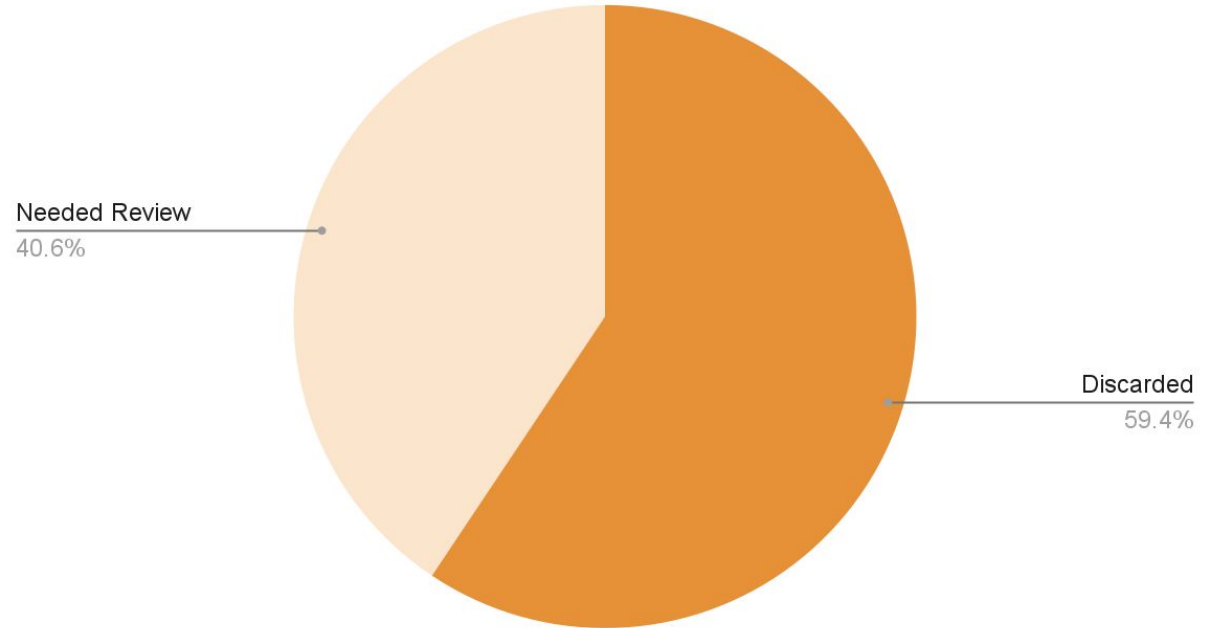
# Crews Control Powered Threat Model

*Statistics about TP/FP*

**Total:** 60

**Needed review:** 24

PRD Review Decision Split



# In-House Grown AI Solution

## *Considerations*

### Budget

- Expensive model
- Local model
- Delay adoption
- Buy a solution

### Skills

- Who will support
- Feature enhancement planning
- Training and onboarding
- Requires a triage owner

### Integration

- CI/CD
- CLI - local
- Project Management
- SCM

### PR

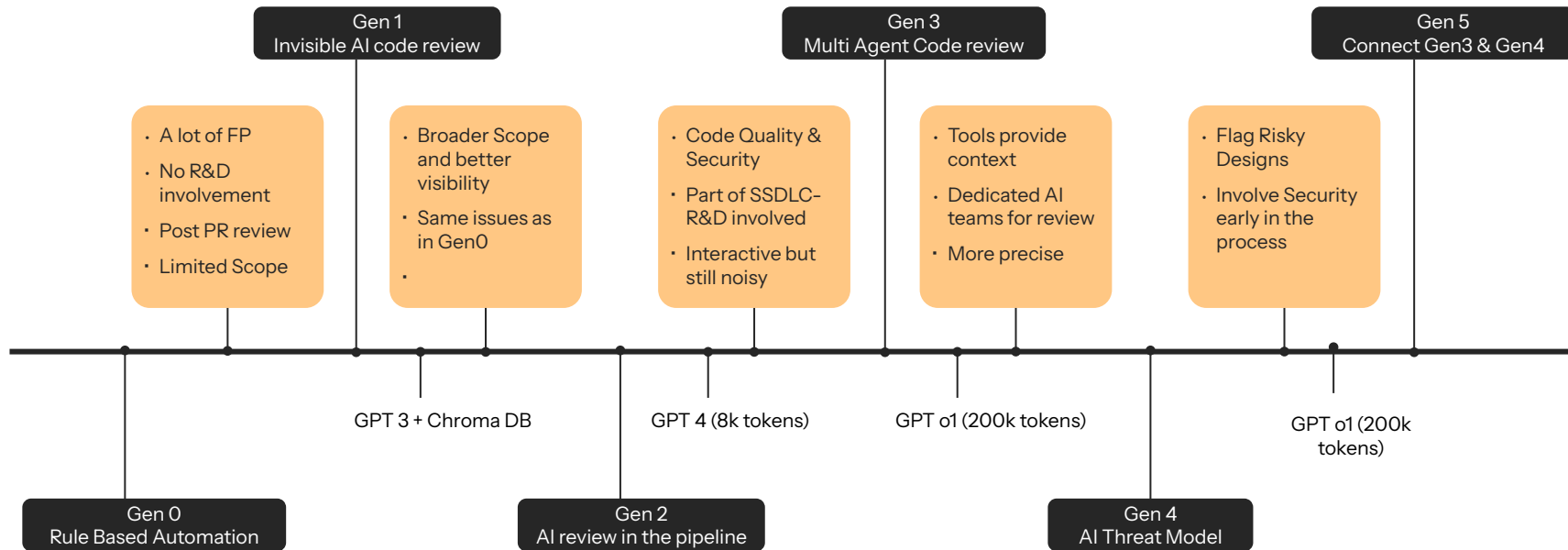
- Minimal R&D disruption
- R&D features (code quality)

### Interaction

- Comment to developer
- Jira
- Slack
- Block Merge

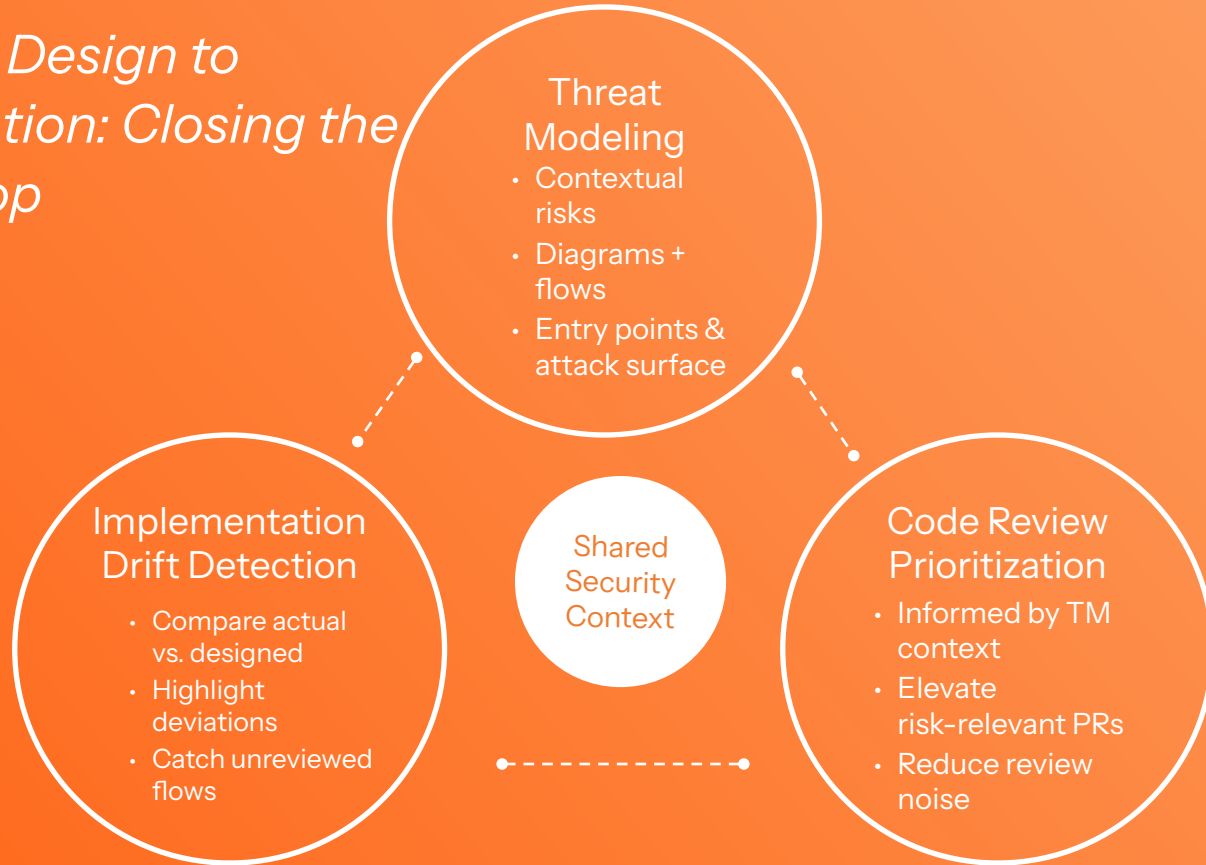
# The Future

## *The Journey*



# The Vision

## *Connecting Design to Implementation: Closing the Security Loop*





CrewsControl  
GitHub Repo



# Thank You



Q&A